

MAINCRAFTS TECHNOLOGY

Vulnerability Assessment Report

Task-3: Vulnerability Scanning & Assessment

Target Application: Damn Vulnerable Web Application (DVWA)
Deployment: Dockerized container on Kali Linux host (127.0.0.1:8080)
Classification: Internal / Lab Use Only

Prepared by: SOUVIK DAS
Role: Cybersecurity Intern

Table of Contents

1. Executive Summary	3
2. Methodology	3
2.1 Scope.....	3
2.2 Target Environment	4
2.3 Tools Used.....	4
2.4 Rules of Engagement	5
2.5 Commands Executed	5
3. Technical Findings.....	5
3.1 Nmap Findings — Host Discovery & Port/Service Enumeration.....	5
3.2 Nikto Findings — Web Server Misconfiguration Scan	6
3.3 Dirsearch Findings — Hidden File & Directory Enumeration.....	7
4. Impact Analysis	8
5. Risk Rating.....	8
6. Remediation Recommendations	9
7. Conclusion & Next Steps.....	10
Appendix A: Evidence Index	11

1. Executive Summary

This report presents the findings of a vulnerability assessment performed against the Damn Vulnerable Web Application (DVWA), an intentionally vulnerable training platform, deployed inside a Docker container on a Kali Linux host. The assessment was carried out as part of Task-3 of the Maincrafts Technology cybersecurity internship, and simulates the reconnaissance and scanning phase that a real-world security analyst or penetration tester would perform before any exploitation or patching activity.

The engagement was strictly passive-to-active scanning in nature; no exploitation, data manipulation, or denial-of-service activity was performed against the target, consistent with the defined rules of engagement.

The assessment identified a total of 8 categories of findings across the network and web application layers, ranging from Medium to Informational severity. No Critical-severity issues were identified during this scan phase. The most significant issues relate to an outdated web server version, the absence of several recommended HTTP security headers, insecure cookie attributes, and directory listing/information disclosure on two web paths. These findings are consistent with what is expected of DVWA, which is deliberately built with insecure defaults for training purposes.

The table below summarizes the overall risk distribution of findings identified in this assessment.

Risk Rating	Number of Findings	Examples
High	0	—
Medium	4	Outdated Apache, missing security headers, insecure cookies, directory listing
Low	3	Exposed source files, admin login page, default Apache files
Informational	1	Unexplained secondary open port (44739/tcp)

These findings, while low-to-medium in isolation, would in combination give an attacker meaningful reconnaissance value: outdated software fingerprinting, session-hijacking opportunities via missing cookie flags, and information disclosure through directory listings and exposed configuration/version-control artifacts. Remediation guidance for each finding is provided in Section 5.

2. Methodology

2.1 Scope

This assessment was limited strictly to the lab environment described below. No systems outside this scope were tested.

In-Scope	Out-of-Scope
Local DVWA lab container only	Any system outside the lab environment

In-Scope	Out-of-Scope
Passive and active scanning	Exploit attempts
Web and network layer visible issues	System destruction / denial-of-service
Nmap, Nikto, Dirsearch scanning	Real-world / third-party websites

2.2 Target Environment

For this experiment, Damn Vulnerable Web Application (DVWA) was used as the target application. DVWA is an intentionally vulnerable PHP/MySQL web application built for security professionals and students to legally practice common web vulnerabilities in a controlled environment.

- Host operating system: Kali Linux (attacker/analyst workstation)
- Target application: DVWA (Damn Vulnerable Web Application), deployed via Docker (vulnerables/web-dvwa image)
- Target address: 127.0.0.1, published container port 8080 (mapped to container port 80)
- Rationale: the container was published to the loopback interface of the same Kali host, so 127.0.0.1:8080 was used consistently as the assessment target across all tools rather than the internal Docker bridge IP, in order to reflect how the service is actually reachable.

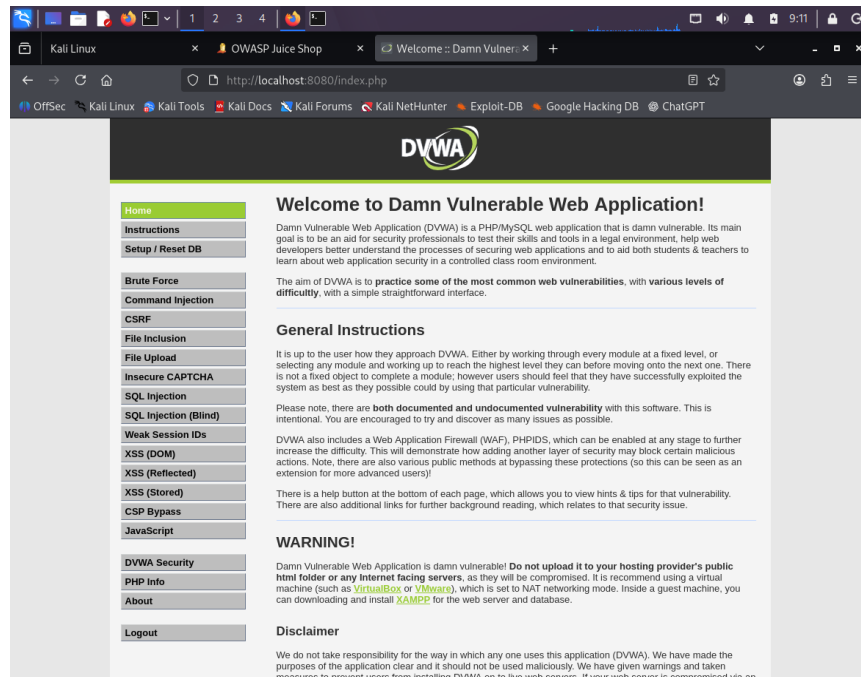


Figure 1: DVWA welcome/login page accessible at <http://localhost:8080/index.php>, confirming the target application and version in scope for this assessment.

2.3 Tools Used

Tool	Purpose
Nmap 7.99	Host discovery and full TCP port/service/version enumeration

Tool	Purpose
Nikto v2.6.0	Web server misconfiguration and known-issue scanning
Dirsearch v0.4.3	Hidden directory and file enumeration via wordlist brute-forcing

2.4 Rules of Engagement

- All testing was conducted exclusively against the local, self-hosted DVWA lab instance.
- No exploitation, credential brute-forcing, or intrusive payloads were used at this stage — only enumeration and passive/active scanning as permitted under the Task-3 scope.
- Exploitation of the vulnerabilities identified here is explicitly deferred to Task-4, per the assignment brief.

2.5 Commands Executed

```
nmap -sn 127.0.0.1 -oN ~/lab/scans/host-discovery.txt
nmap -sV -p- 127.0.0.1 -oN ~/lab/scans/full-service-scan.txt
nikto -h http://127.0.0.1:8080 -o ~/lab/scans/nikto.txt
dirsearch -u http://127.0.0.1:8080 -o ~/lab/scans/dirsearch.txt
```

3. Technical Findings

The following findings were identified during host discovery, port/service enumeration, web server scanning, and directory brute-forcing against the DVWA container. Each finding includes supporting evidence, an explanation, and its associated risk rating; impact and remediation are detailed in Sections 4 and 5 respectively.

3.1 Nmap Findings — Host Discovery & Port/Service Enumeration

Nmap was used first to confirm the target was live, then to perform a full TCP port and service/version scan against 127.0.0.1.

```
(peter@kali) [~]
$ sudo nmap -sn 127.0.0.1 -oN ~/lab/scans/host-discovery.txt
[sudo] password for peter:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-04 09:08 +0100
Nmap scan report for localhost (127.0.0.1)
Host is up.
Nmap done: 1 IP address (1 host up) scanned in 0.01 seconds
(peter@kali) [~]
```

```
(peter@kali)-[~]
$ nmap -sV -p- 127.0.0.1 -oN ~/lab/scans/full-service-scan.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-04 09:08 +0100
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000020s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
8080/tcp  open  http      Apache httpd 2.4.25 ((Debian))
44739/tcp open  http      Golang net/http server
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port44739-TCP:V=7.99%I=7%D=7/4%Time=6A48BF72%P=x86_64-pc-linux-gnu%r(Ge
SF:nericLines,67,"HTTP/1.1\x20400\x20Bad\x20Request\r\nContent-Type:\x20t
SF:ext/plain;\x20charset=utf-8\r\nConnection:\x20close\r\n\r\n400\x20Bad\x
SF:20Request")%r(GetRequest,8F,"HTTP/1.0\x20404\x20Not\x20Found\r\nDate:\
SF:x20Sat,\x2004\x20Jul\x202026\x2008:08:18\x20GMT\r\nContent-Length:\x201
SF:9\r\nContent-Type:\x20text/plain;\x20charset=utf-8\r\n\r\n404:\x20Page\
SF:x20Not\x20Found")%r(HTTPOptions,8F,"HTTP/1.0\x20404\x20Not\x20Found\r\
SF:nDate:\x20Sat,\x2004\x20Jul\x202026\x2008:08:18\x20GMT\r\nContent-Lengt
SF:h:\x2019\r\nContent-Type:\x20text/plain;\x20charset=utf-8\r\n\r\n404:\x
SF:20Page\x20Not\x20Found")%r(RTSPRequest,67,"HTTP/1.1\x20400\x20Bad\x20R
SF:quest\r\nContent-Type:\x20text/plain;\x20charset=utf-8\r\nConnection:\
SF:x20close\r\n\r\n400\x20Bad\x20Request")%r(Help,67,"HTTP/1.1\x20400\x20
SF:Bad\x20Request\r\nContent-Type:\x20text/plain;\x20charset=utf-8\r\nConn
SF:ection:\x20close\r\n\r\n400\x20Bad\x20Request")%r(SSLSessionReq,67,"HTT
SF:P/1.1\x20400\x20Bad\x20Request\r\nContent-Type:\x20text/plain;\x20char
SF:set=utf-8\r\nConnection:\x20close\r\n\r\n400\x20Bad\x20Request")%r(Four
SF:0hFourRequest,8F,"HTTP/1.0\x20404\x20Not\x20Found\r\nDate:\x20Sat,\x20
SF:04\x20Jul\x202026\x2008:08:33\x20GMT\r\nContent-Length:\x2019\r\nConten
SF:t-Type:\x20text/plain;\x20charset=utf-8\r\n\r\n404:\x20Page\x20Not\x20F
SF:ound")%r(LPDSstring,67,"HTTP/1.1\x20400\x20Bad\x20Request\r\nContent-Ty
SF:pe:\x20text/plain;\x20charset=utf-8\r\nConnection:\x20close\r\n\r\n400\
SF:x20Bad\x20Request")%r(SIPOptions,67,"HTTP/1.1\x20400\x20Bad\x20Request
```

Figure 2: Nmap host discovery and full port/service scan showing Apache 2.4.25 on port 8080/tcp and an unidentified secondary service on 44739/tcp.

Finding 1: Outdated Apache HTTP Server Version [Medium]

Description: The Nmap version scan fingerprinted the web service as Apache httpd 2.4.25 (Debian). This was independently corroborated by Nikto, which flagged the version as outdated, noting that current stable releases are at least 2.4.66.

Evidence: nmap full-service-scan.txt — "8080/tcp open http Apache httpd 2.4.25 ((Debian))"; nikto.txt — "Apache/2.4.25 appears to be outdated (current is at least 2.4.66)".

Finding 2: Secondary Unidentified Open Port (44739/tcp) [Informational]

Description: The full TCP port scan revealed a second open port, 44739/tcp, running an HTTP service identified by Nmap only as a "Golang net/http server" — the exact application could not be fingerprinted.

Evidence: nmap full-service-scan.txt — "44739/tcp open http Golang net/http server" with an unmatched service fingerprint.

Note: This port is very likely an internal Docker Desktop or container-runtime helper process rather than part of the DVWA application itself, but it was not exploited or further identified in this task and is documented here for completeness, since any unidentified open port increases the host's attack surface.

3.2 Nikto Findings — Web Server Misconfiguration Scan

Nikto was run against http://127.0.0.1:8080 to identify web server misconfigurations, missing security controls, and known outdated components.

```

nmap done: 1 IP address (1 host up) scanned in 20.69 seconds
(peter@kali)-[~]
$ nikto -h http://127.0.0.1:8080 -o ~/lab/scans/nikto1.txt
- Nikto v2.6.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 8080
+ Platform: Linux/Unix
+ Start Time: 2026-07-04 09:09:13 (GMT1)

+ Server: Apache/2.4.25 (Debian)
+ ERROR: Failed to check for updates: 403
+ [95] /: Cookie PHPSESSID created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ [95] /: Cookie security created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [600050] Apache/2.4.25 appears to be outdated (current is at least 2.4.66).
+ [750500] /config/: Directory indexing found.
+ [000998] /config/: Configuration information may be available remotely.
+ [750500] /docs/: Directory indexing found.
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ [006333] /login.php: Admin login page/section found.

```

Figure 3: Nikto scan output showing missing security headers, insecure cookie flags, directory indexing, an outdated Apache banner, and the discovered admin login page.

Finding 3: Missing Recommended HTTP Security Headers [Medium]

Description: Nikto identified that the DVWA web server does not return several security-relevant HTTP response headers, including Content-Security-Policy, X-Content-Type-Options, Referrer-Policy, Permissions-Policy, and Strict-Transport-Security.

Evidence: nikto.txt — five separate "Suggested security header missing" entries for the headers listed above.

Finding 4: Session Cookies Missing HttpOnly Flag [Medium]

Description: The PHPSESSID and security cookies issued by the application are created without the HttpOnly attribute, meaning they can be accessed by client-side JavaScript.

Evidence: nikto.txt — "Cookie PHPSESSID created without the httponly flag"; "Cookie security created without the httponly flag".

Finding 5: Directory Listing / Information Disclosure [Medium]

Description: Directory indexing is enabled on the /config/ and /docs/ paths, allowing an unauthenticated visitor to browse the contents of these directories directly. Nikto additionally noted that configuration information may be available remotely via /config/.

Evidence: nikto.txt — "/config/: Directory indexing found", "/config/: Configuration information may be available remotely", "/docs/: Directory indexing found"; independently corroborated by Dirsearch, which returned HTTP 200 responses for both /config/ and /docs/ (see Section 3.3).

Finding 6: Apache Default File Disclosure [Low]

Description: The default Apache placeholder file /icons/README is still accessible, confirming the use of a stock Apache configuration that has not been hardened.

Evidence: nikto.txt — "/icons/README: Apache default file found".

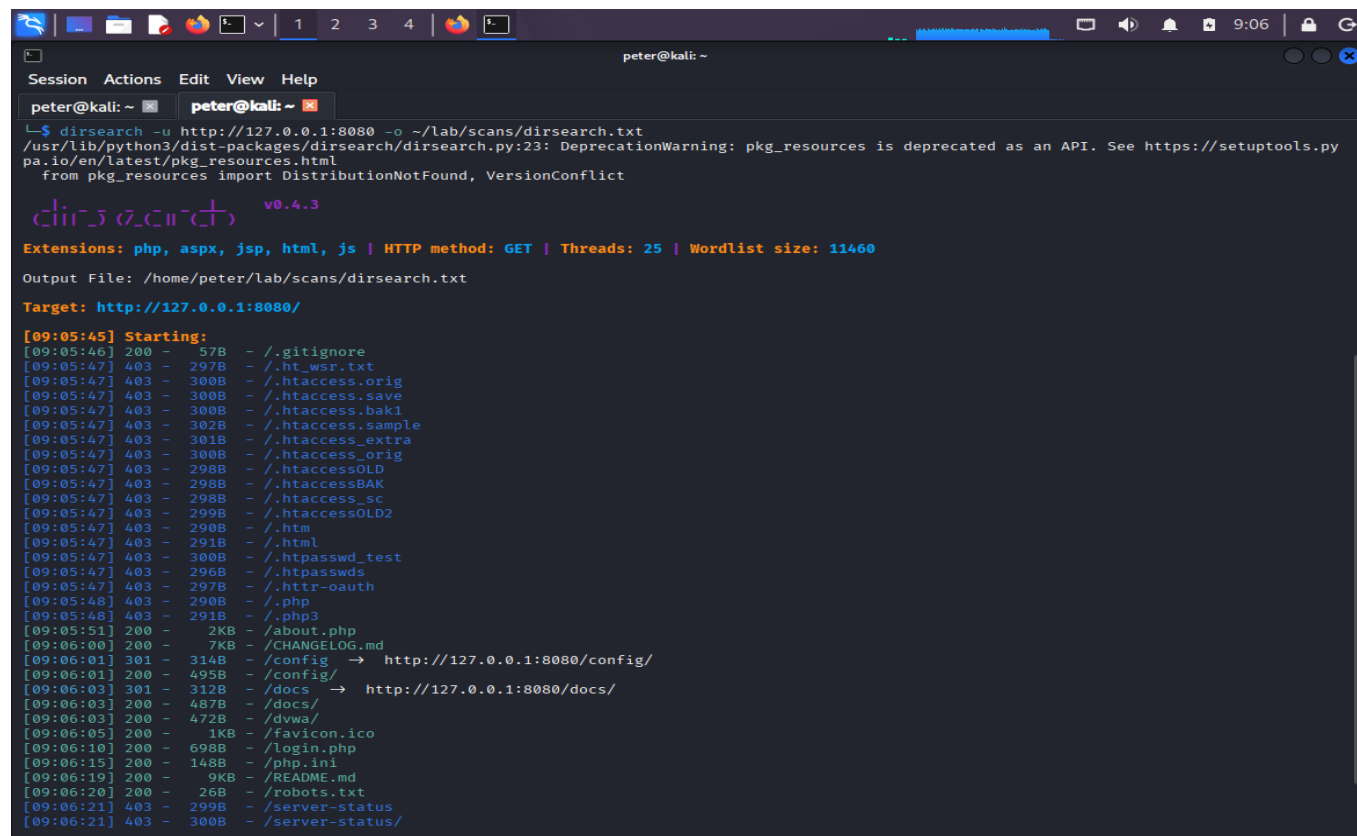
Finding 7: Publicly Accessible Administrative Login Page [Low]

Description: The DVWA login page (/login.php) is directly reachable without any network-level restriction (e.g. IP allow-listing or VPN gating).

Evidence: nikto.txt — "/login.php: Admin login page/section found"; independently corroborated by Dirsearch (see Section 3.3).

3.3 Dirsearch Findings — Hidden File & Directory Enumeration

Dirsearch was run against <http://127.0.0.1:8080> using its default wordlist to brute-force hidden files and directories not linked from the application's normal navigation.



```

peter@kali: ~
Session Actions Edit View Help
peter@kali: ~ peter@kali: ~
└─$ dirsearch -u http://127.0.0.1:8080 -o ~/lab/scans/dirsearch.txt
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.py
pa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460

Output File: /home/peter/lab/scans/dirsearch.txt

Target: http://127.0.0.1:8080/

[09:05:45] Starting:
[09:05:46] 200 - 57B - /.gitignore
[09:05:47] 403 - 297B - /.ht_wsr.txt
[09:05:47] 403 - 300B - /.htaccess.orig
[09:05:47] 403 - 300B - /.htaccess.save
[09:05:47] 403 - 300B - /.htaccess.bak1
[09:05:47] 403 - 302B - /.htaccess.sample
[09:05:47] 403 - 301B - /.htaccess_extra
[09:05:47] 403 - 300B - /.htaccess_orig
[09:05:47] 403 - 298B - /.htaccessOLD
[09:05:47] 403 - 298B - /.htaccessBAK
[09:05:47] 403 - 298B - /.htaccess_sc
[09:05:47] 403 - 299B - /.htaccessOLD2
[09:05:47] 403 - 290B - /.htm
[09:05:47] 403 - 291B - /.html
[09:05:47] 403 - 300B - /.htpasswd_test
[09:05:47] 403 - 296B - /.htpasswd
[09:05:47] 403 - 297B - /.httr-oauth
[09:05:48] 403 - 290B - /.php
[09:05:48] 403 - 291B - /.php3
[09:05:51] 200 - 2KB - /about.php
[09:06:00] 200 - 7KB - /CHANGELOG.md
[09:06:01] 301 - 314B - /config → http://127.0.0.1:8080/config/
[09:06:01] 200 - 495B - /config/
[09:06:03] 301 - 312B - /docs → http://127.0.0.1:8080/docs/
[09:06:03] 200 - 487B - /docs/
[09:06:03] 200 - 472B - /dvwa/
[09:06:05] 200 - 1KB - /favicon.ico
[09:06:10] 200 - 698B - /login.php
[09:06:15] 200 - 148B - /php.ini
[09:06:19] 200 - 9KB - /README.md
[09:06:20] 200 - 26B - /robots.txt
[09:06:21] 403 - 299B - /server-status
[09:06:21] 403 - 300B - /server-status/

```

Figure 4: Dirsearch output enumerating accessible files and directories on the DVWA instance, including exposed configuration and documentation files, and corroborating the /config/, /docs/, and /login.php findings from Nikto.

Finding 8: Exposed Source Control and Configuration Artifacts [Low]

Description: Dirsearch enumeration revealed that several files not intended for production/public exposure are directly accessible, including .gitignore, CHANGELOG.md, README.md, php.ini, and setup.php. These can reveal internal file structure, software versioning, and build/configuration details useful to an attacker during reconnaissance.

Evidence: dirsearch.txt — HTTP 200 responses for /.gitignore, /CHANGELOG.md, /README.md, /php.ini, and /setup.php.

4. Impact Analysis

The table below maps each technical finding to its potential real-world security impact if this were a production system rather than an isolated training lab.

Finding	Business / Security Impact
Outdated Apache 2.4.25	Older server versions may contain publicly known, unpatched vulnerabilities (CVEs). Version fingerprinting also gives attackers a head start when selecting exploits.
Unidentified port 44739	Any unmonitored or unidentified open service expands the attack surface and could be leveraged for lateral movement or as an overlooked entry point if left unmanaged.
Missing security headers	Absence of CSP/X-Content-Type-Options increases exposure to cross-site scripting (XSS) and MIME-sniffing attacks; missing HSTS increases exposure to protocol downgrade/interception on production deployments.
Cookies without HttpOnly	If an XSS vulnerability is present elsewhere in the app (DVWA has several by design), session cookies could be stolen via client-side script, leading to session hijacking.
Directory listing / config exposure	Reveals internal file layout and configuration details, aiding attacker reconnaissance and potentially exposing sensitive settings or credentials if present in listed files.
Exposed source/config files	Version-control and changelog files can reveal software versions, past vulnerabilities that were patched, and internal development practices useful for targeted attacks.
Apache default files	Low direct impact, but confirms an unhardened, default installation, which typically correlates with other missed hardening steps.
Exposed admin login page	Provides attackers a known entry point for credential brute-forcing or credential-stuffing attacks against the administrative interface.

5. Risk Rating

Risk ratings were assigned using a qualitative Critical / High / Medium / Low / Informational scale, based on the likelihood of exploitation and the potential impact, consistent with standard vulnerability assessment practice (e.g. OWASP risk rating methodology).

Finding	Risk Rating	Justification
Outdated Apache 2.4.25	Medium	Known outdated software with potential unpatched CVEs, though no active exploit was confirmed in this task.
Missing security headers	Medium	Weakens browser-side defenses; increases exploitability of other web flaws.

Finding	Risk Rating	Justification
Cookies without HttpOnly	Medium	Direct enabler of session hijacking if combined with XSS.
Directory listing / config exposure	Medium	Confirmed information disclosure on two live paths.
Exposed source/config files	Low	Reconnaissance value only; no credentials or secrets confirmed exposed.
Apache default files	Low	Cosmetic/hardening indicator rather than a directly exploitable flaw.
Exposed admin login page	Low	Expected for this application type; risk depends on authentication strength, not tested here.
Unidentified port 44739	Informational	Not confirmed to be part of the target application; flagged for awareness only.

6. Remediation Recommendations

The following remediation steps are recommended for each finding. As DVWA is an intentionally vulnerable training application, these steps are illustrative of best practice and are directly applicable to real production deployments running similar software stacks.

Finding	Recommended Remediation
Outdated Apache 2.4.25	Upgrade Apache HTTP Server to the latest stable release (2.4.66 or later) and apply a regular patch-management cadence.
Missing security headers	Configure the web server (or application middleware) to send Content-Security-Policy, X-Content-Type-Options: nosniff, Referrer-Policy, Permissions-Policy, and Strict-Transport-Security headers on all responses.
Cookies without HttpOnly	Set the HttpOnly (and Secure, where HTTPS is used) attribute on all session cookies to prevent client-side script access.
Directory listing / config exposure	Disable directory indexing (Options -Indexes in Apache) for all web-accessible directories and remove or relocate configuration files out of the public web root.
Exposed source/config files	Remove development/version-control artifacts (.gitignore, CHANGELOG.md, README.md, setup.php, php.ini) from the production web root, or block access to them via server configuration.
Apache default files	Remove or restrict access to default Apache files (e.g. /icons/) as part of standard server hardening.
Exposed admin login page	Restrict access to administrative interfaces via IP allow-listing, VPN, or an authentication gateway, and enforce strong password/lockout policies.

Finding	Recommended Remediation
Unidentified port 44739	Identify the owning process (e.g. via docker ps / lsof) and close or firewall the port if it is not required to be exposed.

7. Conclusion & Next Steps

This assessment successfully completed the reconnaissance and vulnerability identification phase against the DVWA lab target, fulfilling the objectives of Task-3: host discovery, port and service enumeration, web misconfiguration detection, hidden endpoint discovery, and formal documentation of findings with remediation guidance.

A total of 8 findings were documented, with the most significant being outdated server software, missing HTTP security headers, insecure cookie handling, and directory-listing-based information disclosure. No exploitation was performed, in line with the defined rules of engagement for this task.

As outlined in the task brief, the next phase (Task-4) will build on these findings by performing controlled exploitation and deeper web application security testing against the identified weak points, moving from identification to validated proof-of-concept.

Appendix A: Evidence Index

The following raw scan output files accompany this report as a separate evidence folder submission.

Evidence Item	Description
host-discovery.txt	Nmap host discovery (-sn) raw scan output confirming target reachability.
full-service-scan.txt	Nmap full TCP port and service/version scan (-sV -p-) raw output.
nikto.txt	Nikto web server misconfiguration scan raw output.
dirsearch.txt	Dirsearch hidden file/directory enumeration raw output.
Screenshots (Figures 1-4)	Terminal and browser screenshots captured during the assessment, embedded in Section 3 of this report.